

Nightingale Shared Care Note

A trust-first clinical collaboration prototype for one longitudinal patient record

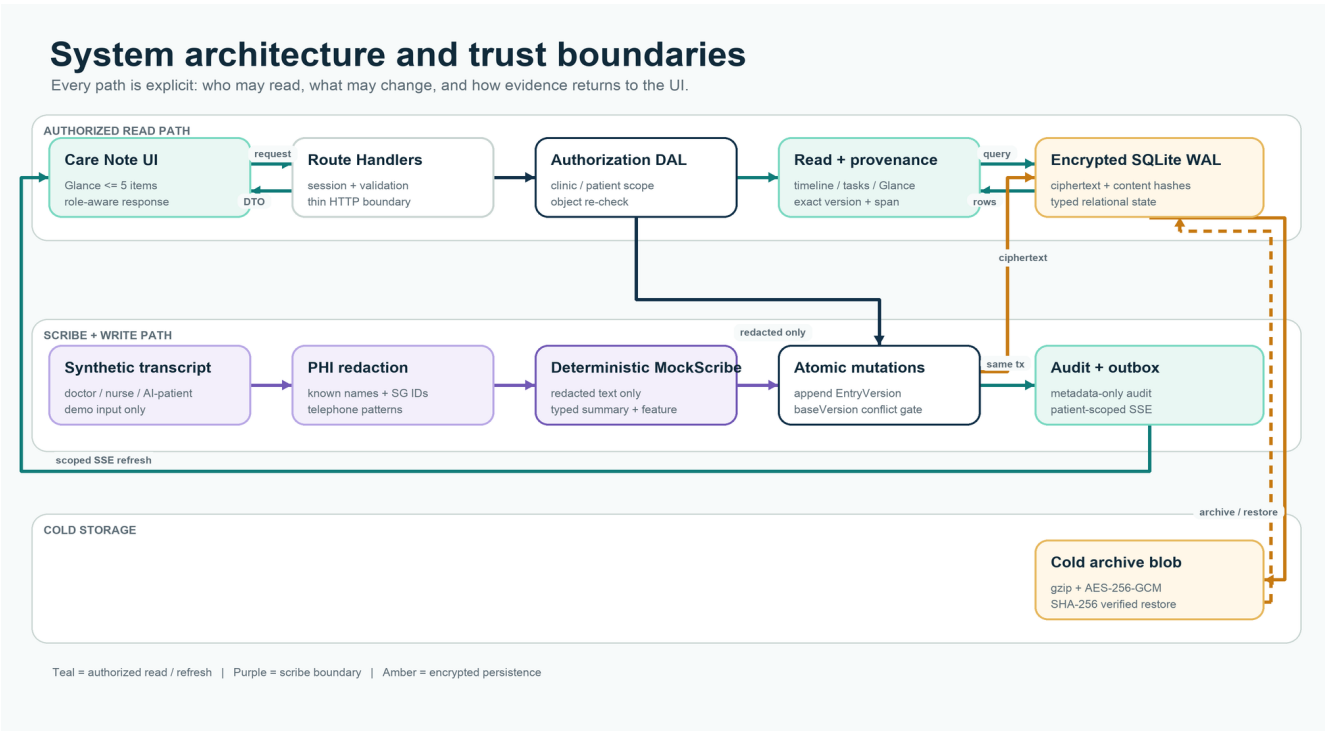
1. What I built and why

During a consult, the expensive task is not writing another note. It is finding what changed, what is still open, and whether a claim can be trusted. I kept the timeline as the record of fact and made Glance a five-item working set. It favors risk, unfinished work, clinician-confirmed corrections, and recent change. Each item says why it is shown and opens the exact stored source span.

BUILT	LEFT OUT
Role-owned entries, comments and assignments, tasks, full snapshots, append-only revert, deterministic 409 conflicts, patient-safe updates, exact provenance, reversible feedback, connection-aware SSE, admin audit, and cold archive.	Voice capture, transcription, diarization, a real model provider, EHR integration, and any claim that the prototype may handle real patient data.

One TypeScript repository contains the Next.js 16.3.2 UI, Route Handlers, SSE endpoint, and server data-access layer. Prisma 7.9.1 uses the better-sqlite3 adapter against one local SQLite WAL database.

Assumption: a synthetic, single-region clinic demo with seeded identities and stable loopback connectivity. **First principle:** a summary must not become a second source of truth; authorization stays server-side, writes stay append-only, and derived claims resolve to immutable evidence.

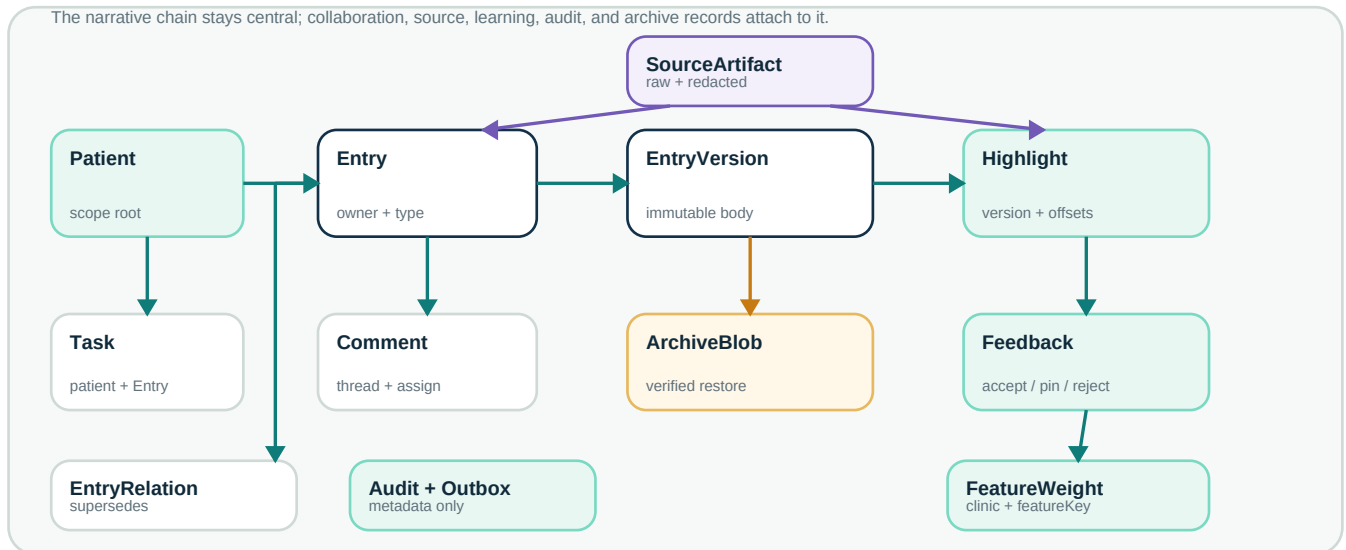


1. READ	2. WRITE	3. SCRIBE	4. REFRESH
Route authenticates; DAL checks scope again before the object query.	Mutation appends ciphertext only after the base-version gate succeeds.	Local summary logic receives the redacted string; no provider call exists.	The same transaction stores audit metadata and an SSE outbox event.

Clinical narrative fields are encrypted, but identifiers and control metadata are not. The redactor is a narrow pattern matcher, not a production DLP system. These are explicit reasons the build remains synthetic-data only.

2. Data model and trust mechanics

The timeline stays authoritative. Derived signals point back to an immutable version rather than becoming a second source of truth.



Narrative and revision

Entry holds ownership, role, type, visibility, section, risk, current version, and source or correction links. The body exists only in **EntryVersion**. Revert decrypts a chosen snapshot and appends a new version with **revertedFromVersion**; it does not delete history. A write increments **currentVersion** only when it still equals **baseVersion**. Two writes to different Entries succeed. The losing writer to the same Entry receives **409 VERSION_CONFLICT**.

Provenance and correction

A SourceArtifact produces a distinct system-owned Entry; its interaction type maps to doctor-patient, nurse-patient, or AI-patient summary types. A Highlight cites one immutable EntryVersion plus start and end offsets. It may also point to the original artifact. Resolution repeats authorization, reads hot or archived content, checks the plaintext hash, and returns the exact slice. A clinician correction creates a new Entry and a **supersedes** relation, so the earlier statement remains reviewable.

Server-side role boundaries

Patients receive only **visibility=patient** instructions and patient-authored insights. Glance, tasks, comments, raw artifacts, and audit fields are absent from their payload. Staff and clinicians may edit only entries they authored in their own role. Cross-clinic reads return 404. The clinic-scoped admin can inspect metadata-only audit events and reset synthetic data only in development.

Collaboration and live refresh

Threaded comments attach to an Entry and support assignment plus resolve/reopen. Tasks stay separate because work state should not be buried inside prose. History and Comments are true filtered views. Every mutation writes audit metadata and an EventOutbox row in the same transaction. The 25-second SSE connection sends metadata only after authorization; the UI exposes connecting/live/reconnecting state before refetching the role-filtered care note.

Clinical free text in versions, comments, tasks, highlights, reasons, and source artifacts uses AES-256-GCM. Audit rows keep actor, action, object IDs, versions, and non-sensitive control metadata. Unauthorized object access returns 404 when revealing existence would leak scope.

3. Evidence, trade-offs, and the next boundary

The claims below come from the final candidate working tree and a fresh local run on 27 August 2026.

Check	Current result	What it proves
Static checks	ESLint, TypeScript, production build: PASS	The final candidate build completes a production build.
Core tests	Vitest 5/5	Encryption, redaction order, scoring, archive round-trip.
HTTP micro-tests	10/10 test cases	RBAC, patient persistence, history, provenance, conflicts, feedback undo.
SQLite scan	4 seeded phrases absent	Known clinical free text is not stored in plaintext.
Warm path	P50 6.53 ms P95 12.01 ms	200 requests, concurrency 10; gate P95 < 300 ms.

The benchmark ran on an Apple M4 with 16 GB RAM and Node 24.14.0 after 50 warmups, with 200 measured requests at concurrency 10. It is a local acceptance result, not a production capacity claim.

Importance logic and the honest boundary

base = risk + unresolved task + clinician confirmation + entity + freshness
learned = clamp(clinic feature weight, -15, 15)
final = clamp(base + learned, 0, 100)

Accept and pin add +2; reject adds -2; undo_reject adds the inverse +2 and restores the suggestion. Every action is auditable and cannot erase provenance.

CURRENT LEARNING BEHAVIOR	NEXT ACCEPTANCE TEST
Feedback updates clinic-scoped FeatureWeight and re-scores matching stored highlights. Reject is reversible through an auditable inverse update.	Read FeatureWeight during ingest, create a second similar suggestion, and assert that its score inherits the learned priority without changing provenance.

Trade-offs

Choice	Why it fit 72 hours	Limit / next step
SQLite WAL	One local service; easy conflict reproduction.	PostgreSQL, RLS, HA backups, durable outbox consumer.
Full snapshots	Simple revert and stable provenance.	More storage; keep the conservative archive path.
MockScribe	Tests redaction and provenance without disclosure.	Redacted-only provider interface, DLP, evals, model governance.
Polling SSE	Small and inspectable collaboration path.	Broker, backpressure, delivery monitoring, load tests.
Pattern redactor	Deterministic coverage for the demo data.	Not broad PHI detection; replace with tested DLP / NER.

Cold archive

Archive is opt-in. A version must be older than 365 days, low risk, unrelated to open work, and free of accepted, pinned, high-risk, or correction status. Apply gzip-compresses the existing encrypted payload, wraps it in a second AES-256-GCM envelope, verifies SHA-256, and only then marks SQL content cold. Reads verify both the blob hash and original plaintext hash.

Before real data, the project still needs managed identity, CSRF and rate limits, trusted TLS termination, key rotation, formal threat modeling, a formal accessibility and clinical safety evaluation, retention rules, restore drills, and content-free observability. This build demonstrates trust mechanics and reproducible behavior. It does not claim regulatory compliance.